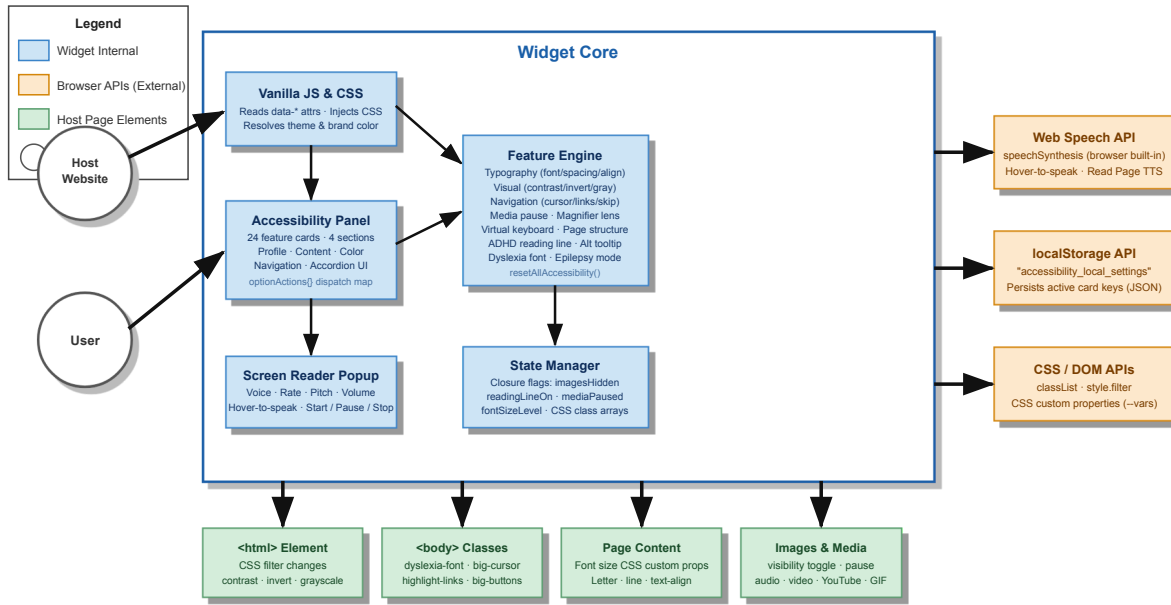


## DWAO Accessibility Widget v2.0.0 — System Architecture Diagram



## Security Findings

| Severity | Finding                                                   | Location                                                                                                                 | Detail                                                                                                                                                                                                                                                  | Recommended Fix                                                                           |
|----------|-----------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|
| HIGH     | XSS via <code>img.alt</code>                              | <code>toggleAltText()</code><br>Line 1224                                                                                | <code>tooltip.innerHTML = img.alt</code> — crafted alt text in any CMS-managed image executes arbitrary HTML/JS in page context.                                                                                                                        | Use <code>tooltip.textContent = img.alt</code>                                            |
| MEDIUM   | <code>getPageStructure()</code><br>Line 1756              | Halts JS execution when DevTools is open. Exposes internal call stack and local variables to anyone inspecting the page. |                                                                                                                                                                                                                                                         |                                                                                           |
| LOW      | Global <code>window</code> pollution                      | Multiple locations                                                                                                       | <code>window._dwaoMouseOver</code> , <code>window._dwaoMouseOut</code> , <code>window._magnifierListeners</code> , <code>window.magnifierEnabled</code> leak onto <code>window</code> . Name collision with host-page scripts silently breaks features. | Move into IIFE closure or namespace under <code>window.DWAOAccessibility._internal</code> |
| LOW      | Brand color CSS injection                                 | Vanilla JS & CSS — Lines 186–190                                                                                         | <code>data-brand-color</code> is string-interpolated directly into CSS without validation. A malformed value can break all widget styles for every visitor.                                                                                             | Validate against <code>/^#[0-9a-f]{3,6}\$ ^rgb\(/i</code>                                 |
| LOW      | Persisted state restored via <code>.click()</code>        | <code>initAccessibilityHandlers</code><br>Line 2229                                                                      | Replaying <code>localStorage</code> by simulating click events triggers <code>speechSynthesis.speak()</code> without a real user gesture — browsers silently block it, breaking TTS restore.                                                            | Call feature functions directly instead of <code>card.click()</code>                      |
| INFO     | <code>innerHTML</code> footgun in <code>createEl()</code> | <code>createEl()</code> — Line 128                                                                                       | All current callers pass static strings — no active XSS path today. But any future caller passing user-controlled content is unsafe with no guard or lint warning.                                                                                      | Add a <code>createElText()</code> variant using <code>textContent</code> for user data    |